

Investigación legal para SATAV

Sistema de Adquisición de TAG Vehicular

Campo	Dato
Institución	Instituto Asunción de Querétaro, A.C.
Proyecto	SATAV - Sistema de Adquisición de TAG Vehicular
Fecha de corte	03 de julio de 2026
Enfoque	Protección de datos personales, aviso de privacidad, firma electrónica, evidencia, nube, menores de edad y videovigilancia
Uso previsto	Documento de apoyo para decisiones internas de Dirección, Administración, TI y área legal

Nota de uso: Este documento presenta una investigación técnica y normativa para orientar el diseño de SATAV. Las decisiones finales de redacción legal, aviso de privacidad y políticas institucionales deberán validarse con el área legal del Instituto.

1. Resumen ejecutivo

- A julio de 2026, el marco principal aplicable es la nueva Ley Federal de Protección de Datos Personales en Posesión de los Particulares publicada en el DOF el 20 de marzo de 2025, vigente desde el 21 de marzo de 2025 y reformada el 14 de noviembre de 2025. La LFPDPPP de 2010 quedó abrogada, por lo que no conviene citar su numeración como vigente. [R2] [R3]
- El IAQ, al ser una asociación civil privada que recaba y usa datos de padres, alumnos, personal y visitantes, debe tratarse como responsable o sujeto regulado para efectos de SATAV. La autoridad federal competente para particulares es la Secretaría Anticorrupción y Buen Gobierno, no el extinto INAI. [R2] [R3]
- SATAV trata datos personales ordinarios: nombre, datos de contacto, tipo de usuario, placas, marca, modelo, color del vehículo, observaciones, firma manuscrita digital, metadatos de aceptación y solicitudes de cambio o baja. Las placas y las imágenes de videovigilancia deben tratarse como datos personales cuando permitan identificar o asociar a una persona. [R2] [R15]
- La firma recomendada para el reglamento de estacionamiento es una firma electrónica simple reforzada: imagen de firma en canvas, trazos vectoriales, hash SHA-256 del texto firmado, sello de tiempo, versión exacta del reglamento y bitácora de aceptación. Este diseño es proporcional al riesgo y evita la fricción de pedir e.firma a padres o alumnos. [R6] [R7] [R8] [R13]
- Para alumnos menores de edad, la aceptación del reglamento y el consentimiento sobre datos deben recabarse del padre, madre o tutor que actúe como gestionante. Una aceptación firmada únicamente por un menor puede ser jurídicamente vulnerable. [R7] [R12]
- El uso de Supabase es viable, pero debe documentarse como tratamiento con proveedor cloud/encargado, con medidas de seguridad verificables: RLS, bucket privado, TLS, cifrado en reposo, MFA para administradores, bitácoras, respaldos y aceptación o conservación del DPA del proveedor. [R4] [R16] [R17] [R18] [R19]
- El aviso general de privacidad del IAQ sirve como base institucional, pero no cubre por sí solo a SATAV. Debe elaborarse un aviso específico o anexo para el trámite del TAG que incluya placas, datos vehiculares, firma electrónica, evidencia digital, nube/Supabase/AWS, finalidades de control vehicular y mecanismo ARCO actualizado. [R2] [R5] [R20]

2. Alcance del sistema analizado

SATAV digitaliza la adquisición y administración del TAG vehicular del estacionamiento escolar. El flujo previsto incluye captura de datos del usuario, datos del vehículo, aceptación del reglamento, firma manuscrita digital, registro del cobro en efectivo y administración de cambios o bajas.

Categoría	Datos o tratamiento	Observación de cumplimiento
-----------	---------------------	-----------------------------

Identificación	Nombre del usuario, nombre del gestionante, tipo de usuario	Dato personal ordinario; requiere aviso de privacidad previo.
Vehículo	Placas, marca, modelo y color	Las placas pueden ser dato personal si identifican o hacen identificable al titular.
Firma	Imagen PNG, trazos vectoriales, nombre del firmante, sello de tiempo	Dato personal y evidencia de aceptación; debe resguardarse en almacenamiento privado.
Evidencia digital	Hash SHA-256, versión del reglamento, bitácora de aceptación	Elemento técnico para probar integridad, atribución y fecha.
Cobro	Registro interno del pago en efectivo de \$100 MXN	No hay pago en línea; debe tratarse como dato administrativo/contable.
Menores	Alumnos de preparatoria que pueden ser menores de 18 años	Debe firmar padre, madre o tutor cuando el usuario sea menor.
Videovigilancia	Cámaras 24 horas en estacionamiento	Requiere cartel/aviso corto e integración con aviso de privacidad.
Nube	Supabase sobre infraestructura cloud y subprocesadores	Debe documentarse proveedor, región, medidas y responsabilidades compartidas.

3. Marco normativo aplicable

Tema	Fundamento principal	Relevancia para SATAV
Protección constitucional de datos	CPEUM, arts. 6 y 16. [R1]	Reconoce privacidad, protección de datos y derechos ARCO.
Ley federal vigente para particulares	LFPDPPP 2025. [R2] [R3]	Regula el tratamiento de datos por particulares como el IAQ.
Reglamento y aviso de privacidad	Reglamento LFPDPPP y Lineamientos del Aviso de Privacidad. [R4] [R5]	Detalla aviso, encargados, nube, medidas de seguridad y modalidades del aviso.
Firma electrónica y mensajes de datos	Código de Comercio, Código Civil Federal y CNPCF. [R6] [R7] [R8]	Sustenta la validez probatoria de firma simple reforzada y mensajes de datos.
Firma electrónica avanzada	Ley de Firma Electrónica Avanzada. [R9]	No es necesaria para SATAV; aplica principalmente a trámites ante APF y supuestos específicos.
Conservación probatoria	NOM-151-SCFI-2016 y PSC acreditados. [R10] [R11]	Mejora opcional para constancias de conservación y fecha cierta.
Menores de edad	LGDNNA y Código Civil Federal. [R7] [R12]	Obliga a privilegiar interés superior y representación por padres/tutores.
Videovigilancia	Criterios y modelos técnicos del INAI como referencia histórica. [R14] [R15]	Apoya el diseño de aviso corto, señalización y retención.
Cloud/Supabase	Documentación oficial de Supabase. [R16] [R17] [R18] [R19]	Sustenta seguridad, regiones, DPA y responsabilidad compartida.

4. Matriz de cumplimiento recomendada

Obligación o riesgo	Recomendación para SATAV	Prioridad	Referencias
Aviso de privacidad previo a la captura	Mostrar aviso simplificado en el formulario y enlazar aviso integral específico SATAV. Conservar versión del aviso aceptado.	Alta	[R2] [R5]
Finalidades específicas	Incluir control de acceso vehicular, administración del TAG, aceptación del reglamento, atención de cambios/bajas, seguridad y registro administrativo del cobro.	Alta	[R2] [R5]
Datos vehiculares	Declarar expresamente placas, marca, modelo y color como datos recabados para control vehicular.	Alta	[R2]
Firma electrónica simple reforzada	Usar canvas + PNG + trazos + hash del reglamento + sello de tiempo + versión + bitácora.	Alta	[R6] [R7] [R8] [R13]
Menores de edad	Cuando el usuario sea alumno menor de 18 años, exigir firma del padre, madre o tutor como gestionante.	Alta	[R7] [R12]
Seguridad de firmas	Guardar firmas en bucket privado; acceso por URL firmada temporal; prohibir URLs públicas permanentes.	Alta	[R2] [R16] [R17]
RLS y mínimo privilegio	Aplicar políticas RLS por rol; escritura por RPC controlada; administradores con MFA.	Alta	[R16] [R17]
Registro de vulneraciones	Definir procedimiento interno para detectar, contener y notificar a titulares cuando haya afectación significativa.	Alta	[R2] [R4]
Nube y encargados	Conservar DPA/Términos de Supabase, identificar subprocesadores y región; reflejarlo en aviso integral.	Media-Alta	[R4] [R16] [R19]
ARCO y revocación	Designar persona/departamento responsable; publicar correo/procedimiento; preparar panel para rectificar, bloquear o cancelar registros.	Alta	[R2]

Videovigilancia	Usar cartel/aviso corto en accesos y aviso integral con finalidad, responsable y retención.	Media-Alta	[R15] [R20]
NOM-151	No indispensable en fase 1; evaluar en fase 2 si Dirección desea mayor fuerza probatoria con constancia de conservación.	Media	[R10] [R11]

5. Análisis del aviso institucional del IAQ

Se revisó el aviso general de privacidad institucional proporcionado como insumo interno. El documento identifica al Instituto Asunción de Querétaro, A.C. como responsable, contiene domicilio institucional, categorías de datos para alumnos, tutores, personal y proveedores, e incluye una finalidad de videovigilancia. Sin embargo, no fue diseñado para SATAV ni para el flujo digital de adquisición del TAG. [R20]

Elemento requerido por SATAV	Situación en aviso general	Recomendación
Control de adquisición y uso del TAG	No aparece como finalidad específica.	Agregar finalidad primaria: administrar solicitudes, emisión, control, cambio y baja del TAG vehicular.
Placas y datos del vehículo	No aparecen como categoría expresa.	Incluir placas, marca, modelo y color del vehículo.
Firma manuscrita digital	Solo se menciona firma autógrafa física en ciertos apartados.	Incluir firma electrónica simple, imagen, trazos, hash, sello de tiempo y versión del reglamento.
Nube/Supabase/AWS	No se menciona proveedor cloud ni tratamiento por encargados.	Informar uso de encargados tecnológicos y, en su caso, ubicación o transferencia/remisión internacional.
Registro del cobro del TAG	Existe referencia genérica a control de ingresos.	Precisar que SATAV registra administrativamente el cobro en efectivo, sin pago en línea.
Videovigilancia	Sí está contemplada como finalidad de seguridad.	Mantenerla, pero complementarla con cartel/aviso corto en estacionamiento y retención definida.
ARCO y autoridad	El aviso debe revisarse contra la ley vigente de 2025.	Actualizar referencias normativas, autoridad competente y procedimiento institucional.

5.1 Recomendación de redacción institucional

Para evitar rehacer todo el aviso general, se recomienda crear un **Aviso de Privacidad Específico para SATAV** o un **Anexo SATAV al Aviso General**, manteniendo el responsable, domicilio y canal institucional, pero agregando las finalidades, datos y encargados propios del sistema. Este aviso debe presentarse antes de la captura de datos y quedar ligado a la aceptación firmada del reglamento.

6. Firma electrónica y evidencia de aceptación

La firma de SATAV no requiere e.firma del SAT ni certificado de firma electrónica avanzada. Para el tipo de operación analizada -aceptación de reglamento interno de estacionamiento escolar-, una firma electrónica simple reforzada es proporcional, usable y defendible si el sistema conserva evidencia suficiente de atribución e integridad.

Elemento de evidencia	Función	Implementación recomendada
Imagen de firma	Evidencia visual de aceptación.	Guardar PNG en bucket privado.
Trazos vectoriales	Refuerzan la evidencia técnica de captura.	Guardar JSON de trazos junto al expediente de firma.
Hash SHA-256	Demuestra integridad del texto firmado.	Calcular sobre reglamento, versión, aviso aceptado y datos del firmante.
Sello de tiempo	Acredita momento de aceptación.	Usar timestamp UTC de base de datos; evaluar NOM-151 como mejora.
Versión del reglamento	Evita ambigüedad sobre qué texto se aceptó.	Tabla <code>reglamento_versiones</code> inmutable.
Bitácora	Ayuda a probar atribución y operación del sistema.	Registrar evento, usuario, fecha, IP/user-agent cuando sea viable.
Cuenta autenticada	Vincula aceptación con persona/gestionante.	Supabase Auth antes de firmar, especialmente para tutores.

La jurisprudencia y criterios sobre mensajes de datos apuntan a que el operador del sistema debe poder probar la fiabilidad del método utilizado. Por ello, SATAV no debe depender únicamente de la imagen de la firma; debe conservar el expediente técnico completo de aceptación. [R6] [R8] [R13]

7. Menores de edad

El sistema contempla alumnos de preparatoria, algunos posiblemente menores de 18 años. La LFPDPPP vigente no desarrolla una regla autónoma específica para menores en particulares, por lo que el tratamiento debe integrarse con el interés superior de niñas, niños y adolescentes, la representación legal y las reglas civiles de capacidad. [R7] [R12]

Recomendación operativa: cuando el usuario del TAG sea menor de edad, SATAV debe registrar al padre, madre o tutor como **gestionante firmante**. El menor puede aparecer como usuario del beneficio vehicular, pero la aceptación del reglamento y el consentimiento de tratamiento de datos deben provenir del representante.

8. Seguridad, nube y Supabase

El uso de Supabase es técnicamente viable si se documenta y configura con controles proporcionales al tratamiento de datos personales. La responsabilidad no se transfiere por completo al proveedor: el IAQ conserva obligaciones como responsable, mientras Supabase opera como proveedor/encargado tecnológico bajo sus términos, DPA y modelo de responsabilidad compartida.

Control	Configuración recomendada	Referencias
Base de datos	RLS activa en todas las tablas con acceso por rol.	[R16] [R17]
Storage	Bucket privado para firmas; no usar objetos públicos.	[R16] [R17]

Autenticación	Supabase Auth con verificación de correo y MFA para administradores.	[R16] [R17]
Transmisión	TLS obligatorio en todo el flujo.	[R16]
Cifrado en reposo	Documentar cifrado reportado por proveedor y respaldos.	[R16]
DPA	Conservar copia/aceptación del Data Processing Addendum.	[R19]
Región	Registrar región elegida y justificarla en expediente técnico.	[R18]
Respaldos	Definir respaldo y restauración; export periódico de evidencias críticas.	[R17]

9. Derechos ARCO, revocación y baja

SATAV debe poder atender acceso, rectificación, cancelación y oposición. La ley vigente conserva plazos operativos relevantes: respuesta al titular y ejecución posterior dentro de los términos previstos por la LFPDPPP. También exige designar una persona o departamento para tramitar solicitudes. [R2]

Derecho/proceso	Cómo debe soportarlo SATAV
Acceso	Exportar expediente del registro: datos capturados, vehículo, firma, aviso/reglamento aceptado y metadatos.
Rectificación	Permitir corrección controlada de datos de contacto, vehículo o usuario con bitácora.
Cancelación	Bloquear o cancelar registros cuando proceda; no borrar evidencia necesaria para obligaciones vigentes.
Oposición/revocación	Registrar solicitud y limitar tratamientos no necesarios cuando aplique.
Cambio o baja de TAG	Usar flujo formal con evidencia de solicitud, autorización y estado final.

10. Videovigilancia y placas vehiculares

El reglamento del estacionamiento menciona videovigilancia 24 horas. Esta mención no sustituye al aviso de privacidad ni al cartel visible de zona videovigilada. La recomendación es mantener un aviso corto en accesos y un aviso integral que explique responsable, finalidad, mecanismos ARCO y retención. [R15] [R20]

Las placas vehiculares deben tratarse como dato personal cuando permitan identificar o asociar el vehículo con un alumno, padre, maestro o empleado. Por ello deben incluirse en el aviso SATAV, protegerse con RLS y limitarse al personal autorizado.

11. NOM-151 y conservación de evidencia

La NOM-151-SCFI-2016 regula constancias de conservación de mensajes de datos emitidas por Prestadores de Servicios de Certificación acreditados. Para SATAV no se identifica como requisito indispensable de fase 1, porque el IAQ no está celebrando un acto mercantil ordinario con especulación comercial mediante el reglamento de estacionamiento. Sin embargo, puede ser una mejora de fase 2 para reforzar fecha cierta e integridad. [R10] [R11]

Opción	Ventaja	Costo/fricción	Recomendación
Hash y sello interno	Sin costo, rápido, suficiente para fase 1 si está bien implementado.	Bajo.	Implementar desde el inicio.
Constancia NOM-151 individual	Mayor fuerza probatoria por tercero acreditado.	Costo por documento.	Evaluar si Dirección prevé litigios o disputas relevantes.
Hash raíz diario con NOM-151	Reduce costo y conserva fuerza temporal para lotes.	Requiere diseño técnico adicional.	Buena mejora de fase 2.

11.1 Criterio de contratación NOM-151

Para SATAV conviene cotizar primero con PSC acreditados que ofrezcan API o integración sencilla para constancias de conservación de mensajes de datos. La decisión debe basarse en: costo por constancia, costo mínimo mensual, facilidad de integración, forma de entrega de la constancia, soporte técnico y confirmación expresa de que el emisor es un Prestador de Servicios de Certificación acreditado por la Secretaría de Economía.

Si el costo por constancia individual resulta alto, SATAV puede reducir el volumen enviando a NOM-151 un hash raíz por lote de aceptaciones, por ejemplo diario, semanal o mensual. En ese modelo el sistema conserva internamente el hash individual de cada aceptación y la prueba de inclusión en el lote; el PSC solo certifica el hash raíz. Esto baja el costo, aunque exige mayor orden técnico para demostrar que una aceptación específica formó parte del lote certificado.

12. Riesgos y decisiones pendientes

Riesgo o decisión	Impacto	Recomendación
Aviso institucional desactualizado o insuficiente para SATAV	Riesgo de incumplimiento informativo.	Aprobar aviso específico SATAV antes de producción.
Firma de menores sin tutor	Riesgo de aceptación impugnabile.	Bloquear flujo para menores sin gestionante firmante.
Firmas en Storage público	Riesgo alto de exposición de datos personales.	Bucket privado y URLs temporales.
Observaciones libres con datos sensibles	Puede elevar obligaciones y sanciones.	Limitar campo, usar catálogo o advertencia operativa.
No documentar Supabase/DPA/región	Brecha documental de cumplimiento.	Guardar expediente técnico y jurídico del proveedor.
Sin proceso ARCO real	Riesgo operativo ante solicitudes.	Designar responsable y preparar procedimiento/panel.
Cobro de \$100 MXN	Posible tratamiento fiscal/contable no definido.	Validar con Administración si requiere recibo, folio o CFDI.
Cláusulas de responsabilidad del estacionamiento	Riesgo civil por daños, robo o límites de responsabilidad.	Validar reglamento con asesoría legal.

13. Plan de acción recomendado

Fase	Acción	Responsable sugerido	Resultado esperado
------	--------	----------------------	--------------------

Antes de producción	Aprobar aviso específico SATAV o anexo al aviso general.	Dirección / Legal / Administración	Texto publicable y versionado.
Antes de producción	Ajustar flujo para mostrar aviso simplificado y casilla de aceptación no premarcada.	TI / Desarrollo	Consentimiento y aceptación trazables.
Antes de producción	Implementar firma simple reforzada con hash, versión y bitácora.	TI / Desarrollo	Expediente técnico de aceptación.
Antes de producción	Configurar RLS, bucket privado, MFA admin y pruebas de acceso.	TI	Controles mínimos de seguridad.
Antes de producción	Definir proceso ARCO/cambio/baja y responsable institucional.	Administración / Legal	Procedimiento operativo.
Primer mes de operación	Revisar registros reales y campos de observaciones para evitar datos excesivos.	Administración / TI	Ajustes de minimización.
Fase 2	Evaluar NOM-151 o hash raíz diario para evidencias.	Dirección / Legal / TI	Decisión costo-beneficio.
Fase 2	Validar reglamento de estacionamiento y responsabilidad civil.	Legal / Dirección	Reglamento alineado a operación.

14. Conclusión

SATAV es viable desde el punto de vista legal y técnico si se implementa con un aviso de privacidad específico, firma electrónica simple reforzada, controles de seguridad en Supabase, tratamiento diferenciado para menores de edad y proceso ARCO real. El principal pendiente no es la tecnología, sino cerrar la documentación institucional: aviso específico, responsable ARCO, política de retención, validación del reglamento y definición administrativa del cobro del TAG.

La recomendación central es avanzar con la implementación, pero condicionar la puesta en producción a la aprobación del aviso SATAV y a la configuración de los controles mínimos de privacidad y seguridad descritos en este documento.

15. Referencias

- [R1] [Constitución Política de los Estados Unidos Mexicanos](#), arts. 6, 16 y 73 fr. XXIX-O
- [R2] [Ley Federal de Protección de Datos Personales en Posesión de los Particulares](#), texto vigente, Cámara de Diputados
- [R3] [Decreto DOF 20-mar-2025 por el que se expide la nueva LFPDPPP y se abroga la ley de 2010](#)
- [R4] [Reglamento de la LFPDPPP](#), texto vigente, Cámara de Diputados
- [R5] [Lineamientos del Aviso de Privacidad](#), DOF 17-ene-2013
- [R6] [Código de Comercio](#), texto vigente, Cámara de Diputados
- [R7] [Código Civil Federal](#), texto vigente, Cámara de Diputados
- [R8] [Código Nacional de Procedimientos Civiles y Familiares](#), texto vigente, Cámara de Diputados
- [R9] [Ley de Firma Electrónica Avanzada](#), Cámara de Diputados
- [R10] [NOM-151-SCFI-2016](#), conservación de mensajes de datos y digitalización de documentos
- [R11] [Directorio de Prestadores de Servicios de Certificación](#), Secretaría de Economía
- [R12] [Ley General de los Derechos de Niñas, Niños y Adolescentes](#), Cámara de Diputados

- [R13] [SCJN, reseña de la Contradicción de Tesis 128/2018, Primera Sala](#)
- [R14] [INAI, documentos y guías para el sector privado](#)
- [R15] [INAI, documentos y guías para el sector privado; referencia técnica histórica para avisos, criterios y modelos](#)
- [R16] [Supabase Security](#)
- [R17] [Supabase, Shared Responsibility Model](#)
- [R18] [Supabase, Platform Regions](#)
- [R19] [Supabase, Data Processing Addendum](#)
- [R20] Aviso General de Privacidad del Instituto Asunción de Querétaro, A.C., documento institucional proporcionado como insumo interno. Archivo interno: [Insumos/Aviso Gral de Privacidad Instituto Asuncion Completo.pdf](#)

Anexo A. Detalle técnico por frente de investigación

Este anexo conserva el detalle técnico necesario para trazabilidad del diseño. Para una lectura ejecutiva basta con las secciones 1 a 14.

A.1. Marco general de protección de datos

A julio de 2026, el tratamiento de datos personales por SATAV se rige por: (i) CPEUM arts. 6 y 16 (párr. 2: derecho a la protección de datos y derechos ARCO) y 73 fr. XXIX-O (competencia federal EXCLUSIVA para legislar sobre datos en posesión de particulares); y (ii) la NUEVA Ley Federal de Protección de Datos Personales en Posesión de los Particulares, publicada en el DOF (edición vespertina) el 20-mar-2025, en vigor desde el 21-mar-2025, que abrogó la ley de 2010; su única reforma es del DOF 14-11-2025 (art. 4, supletoriedad del CNPCyF, aún con vigencia diferida). El IAQ, como persona moral privada (AC), es "responsable"/"sujeto regulado" (arts. 1 y 2 frs. XIV y XVI). La autoridad garante es la Secretaría Anticorrupción y Buen Gobierno (art. 2 fr. XV, arts. 38-39), que ejerce estas funciones vía su Dirección General de Datos Personales en el Sector Privado (Reglamento Interior reformado DOF 21-mar-2025); "Transparencia para el Pueblo" es un órgano desconcentrado que atiende acceso a información de sujetos obligados públicos, no la vía para particulares. El Reglamento LFPDPPP de 2011 sigue publicado como TEXTO VIGENTE (sin nuevo reglamento a julio 2026) y opera en lo que no se oponga a la ley 2025, a la cual la propia ley remite (art. 2 fr. XIII). Multas: hasta 320,000 UMA (~\$37.5M MXN con UMA 2026 = \$117.31), duplicables si hay datos sensibles. La ley estatal de Querétaro solo aplica a sujetos obligados públicos, no al IAQ.

Implicación práctica para SATAV
El IAQ (AC privada) es 'responsable' bajo la LFPDPPP 2025; la autoridad que puede verificarlo y sancionarlo es la Secretaría Anticorrupción y Buen Gobierno (Dirección General de Datos Personales en el Sector Privado), no el INAI (extinto) ni ningún órgano de Querétaro. Cualquier cita legal en el aviso de privacidad o en el doc de firma electrónica de SATAV debe referirse a la ley DOF 20-03-2025 y a la SABG; si el prototipo actual cita la ley de 2010 o al INAI, hay que corregirlo.
SATAV debe mostrar un aviso de privacidad SIMPLIFICADO dentro del formulario web ANTES de recabar nombre/placas/firma (art. 16 fr. II: identidad del responsable, datos tratados, finalidades, opciones de limitación) con enlace a la página del aviso INTEGRAL de 6 elementos (art. 15). Omitirlo es infracción del art. 58 fr. V con multa de 100 a 160,000 UMA (\$11,731 a \$18,769,600 MXN a valores 2026).
Ninguno de los datos de SATAV (nombre, placas, marca/modelo/color, tipo de usuario, firma manuscrita, observaciones) es 'sensible' per se (art. 2 fr. VI), así que basta consentimiento tácito para el tratamiento general; PERO el campo de 'observaciones libres' debe validarse/acotarse para que admins no capturen datos de salud u otros sensibles, porque eso activaría el art. 8 (consentimiento expreso y por escrito) y duplicaría multas (art. 59 fr. IV). El registro del cobro de \$100 MXN es dato patrimonial → cubrirlo con el consentimiento expreso que ya da la firma en canvas y con la excepción de relación jurídica (art. 9 fr. IV).
La firma en canvas cumple de sobra el estándar de consentimiento expreso del art. 8 ('firma autógrafa, firma electrónica, o cualquier mecanismo de autenticación'): el paquete firma PNG + trazos vectoriales + hash SHA-256 + sello de tiempo + versión del reglamento sirve simultáneamente como evidencia de aceptación del reglamento y como constancia de consentimiento del aviso de privacidad, si el texto firmado INCLUYE o referencia la versión exacta del aviso.
Alumnos de preparatoria menores de edad: el consentimiento y la firma deben provenir del padre/madre/tutor (representación del Código Civil Federal, Reglamento 2011 art. 89). El flujo de autoservicio debe capturar fecha de nacimiento o bandera de minoría de edad y bloquear la firma directa del menor, exigiendo que el 'gestionante' declare y firme como quien ejerce la patria potestad; guardar esa declaración junto al hash del documento.

Derechos ARCO operativos: designar formalmente a una persona/área de datos personales (art. 29) —encaja en el rol de Administración del panel—, publicar en el aviso el canal para solicitudes, y cumplir 20 días hábiles para responder + 15 para ejecutar (art. 31). La cancelación NO es borrado inmediato: primero bloqueo por el plazo de prescripción (art. 24) y el IAQ puede negar cancelación mientras el TAG/relación contractual esté vigente (art. 25 frs. I y VI).

Vulneraciones: si se filtra la tabla de registros o el bucket de firmas, hay obligación de notificar a los titulares DE FORMA INMEDIATA (art. 19) con el contenido mínimo del art. 65 del Reglamento; una vulneración imputable al IAQ es infracción de 200 a 320,000 UMA (hasta \$37.5M MXN). SATAV necesita bitácora de accesos y un procedimiento escrito de respuesta a incidentes proporcional a una escuela (art. 60 fr. IV considera la capacidad económica al multar).

Supabase (y AWS debajo) son 'persona encargada': mandar los datos a la nube es remisión, no transferencia (art. 2 fr. XX), así que no requiere consentimiento ni cláusula del art. 35, pero SÍ exige instrumento jurídico (Reglamento arts. 51-52): firmar el DPA de Supabase desde el dashboard, conservarlo como evidencia, y verificar en trust.supabase.com los reportes SOC 2 Type 2 / ISO 27001. Cloudflare y GoDaddy solo ven tráfico/DNS, pero si Cloudflare proxya el sitio conviene incluirlo en el inventario de encargados/subencargados del aviso integral.

A.2. Aviso de privacidad

A julio de 2026 rige la NUEVA Ley Federal de Protección de Datos Personales en Posesión de los Particulares (DOF 20-03-2025, en vigor 21-03-2025, última reforma DOF 14-11-2025 que solo tocó el art. 4), que abrogó la ley de 2010; la autoridad es la Secretaría Anticorrupción y Buen Gobierno (el INAI desapareció). El aviso de privacidad se regula en los arts. 2 fr. I, 14, 15, 16 y 17: el art. 15 fija 6 elementos mínimos (ya no lista transferencias, pero el art. 35 exige una cláusula de aceptación de transferencias en el aviso) y el art. 16 fr. II obliga, cuando los datos se recaban por medios electrónicos (caso SATAV), a mostrar un aviso SIMPLIFICADO con las fracciones I-IV del art. 15 más el sitio del aviso integral. El consentimiento tácito es la regla (art. 7); los datos financieros/patrimoniales exigen consentimiento expreso y los sensibles expreso y por escrito (arts. 7 y 8), con excepción por relación jurídica (art. 9 fr. IV). El Reglamento de 2011 sigue publicado como TEXTO VIGENTE por la Cámara de Diputados (la nueva ley remite a él y no se ha expedido uno nuevo pese al plazo de 90 días del Transitorio Décimo Segundo), y los Lineamientos del Aviso de Privacidad (DOF 17-01-2013) siguen siendo la única norma técnica que detalla las modalidades integral/simplificado/corto, aplicables en lo que no se opongan a la ley nueva. Para SATAV: aviso integral versionado en página propia, aviso simplificado antes del botón de envío del formulario, checkboxes no premarcados, evidencia de puesta a disposición y consentimiento (la carga de la prueba es del responsable, Reglamento arts. 20 y 31) y cartel de aviso corto en el estacionamiento videovigilado.

Implicación práctica para SATAV

SATAV necesita DOS avisos + UN cartel: (1) aviso de privacidad INTEGRAL en página propia del sitio (p.ej. /aviso-de-privacidad) con los 6 elementos del art. 15 LFPDPPP 2025 más la cláusula de transferencias del art. 35 y los mecanismos de revocación del art. 7; (2) aviso SIMPLIFICADO embebido en el formulario de solicitud del TAG ANTES de capturar cualquier dato (art. 16 fr. II: obligatorio en captura por medios electrónicos), con fracciones I-IV del art. 15 y link al integral; (3) cartel de aviso CORTO en los accesos del estacionamiento por la videovigilancia 24h que menciona el reglamento (identidad IAQ, finalidad videovigilancia/seguridad, URL o QR al integral).

Contenido concreto del aviso integral de SATAV: identidad = razón social completa del Instituto Asunción de Querétaro AC y domicilio completo en Querétaro (calle, número, colonia, CP, entidad — Lineamiento Vigésimo primero); datos tratados listados SIN frases vagas: nombre del usuario y del gestionante, placas, marca/modelo/color del vehículo, tipo de usuario, datos de contacto, imagen de la firma manuscrita digital y sus metadatos (trazos, hash SHA-256, sello de tiempo, versión del reglamento firmada), registro del pago en efectivo de \$100 MXN, observaciones; declaración expresa de que NO se recaban datos sensibles; finalidades PRIMARIAS (tramitar y emitir el TAG, control de acceso vehicular, acreditar la aceptación del reglamento, registro contable del cobro, atención de solicitudes de cambio/baja, videovigilancia para seguridad) separadas de las SECUNDARIAS opcionales si las hay (estadísticas, comunicaciones no operativas) con casilla de negativa; medios ARCO y revocación ante la persona/departamento de datos personales del IAQ (art. 29) con correo dedicado y el propio formulario de cambios/baja; procedimiento de comunicación de cambios (publicación versionada en la misma URL + aviso en el sitio); cláusula de transferencias que declare que NO se transfieren datos a terceros y que Supabase/AWS/Cloudflare actúan como encargados (remisión, no transferencia).

El registro del cobro de \$100 MXN asociado a la persona conviene tratarlo como dato patrimonial: recabar consentimiento EXPRESO (art. 7 párrafo quinto) mediante checkbox no premarcado o dentro del acto de firma, y así queda cubierto también el estándar 'inequívoco' del Reglamento art. 12; el resto del tratamiento (TAG, reglamento) se sostiene en consentimiento tácito + excepción de relación jurídica (art. 9 fr. IV), que exige del consentimiento pero NO del aviso.

La firma electrónica simple reforzada de SATAV (imagen + trazos + SHA-256 + timestamp + versión del reglamento) es exactamente el mecanismo que el Reglamento art. 19 reconoce para consentimiento expreso 'por escrito' en entorno digital; debe extenderse para cubrir también la ACEPTACIÓN DEL AVISO DE PRIVACIDAD: registrar en el mismo evento la versión y hash del aviso mostrado, porque la carga de la prueba de la puesta a disposición del aviso Y del consentimiento recae siempre en el IAQ (Reglamento arts. 20 y 31; Lineamiento Decimoséptimo).

Alumnos de preparatoria menores de edad: el consentimiento debe otorgarlo quien ejerce la patria potestad/tutela (reglas del Código Civil Federal, Reglamento art. 89) — el flujo del 'gestionante' debe capturar esa relación (padre/madre/tutor firma cuando el alumno es menor) y el aviso debe indicar que las solicitudes ARCO de menores se tramitan vía su representante con acreditación de la representación.

El campo de OBSERVACIONES LIBRES es el mayor riesgo de cumplimiento del aviso: si un usuario o admin captura ahí datos de salud u otros sensibles, el IAQ estaría tratando sensibles sin consentimiento expreso y por escrito (art. 8) y con un aviso que no los identifica (infracción art. 58 fr. V); hay que instruir/validar que no se capturen sensibles y decirlo en la UI.

Omitir elementos del aviso expone al IAQ a multas de 100 a 160,000 UMA (art. 58 fr. V y 59 fr. II) impuestas por la Secretaría Anticorrupción y Buen Gobierno (ya no existe el INAI); recabar el dato patrimonial del pago sin consentimiento expreso, si se considerara exigible, escala a 200–320,000 UMA (art. 58 fr. XIII, 59 fr. III). Cualquier plantilla o texto legal del sistema que mencione al INAI debe referir a la Secretaría.

Cambios al aviso: publicar versión y fecha en la página del aviso es un medio válido de comunicación de cambios (Lineamiento Trigésimo segundo), pero si el IAQ agrega finalidades no necesarias, nuevos datos patrimoniales o transferencias reales, debe emitir NUEVO aviso y recabar nuevo consentimiento antes de usar los datos (art. 11 LFPDPPP; Lineamiento Trigésimo tercero) — no basta cambiar el texto.

A.3. Firma electrónica

La firma electrónica simple entre particulares es plenamente válida en México a julio de 2026. El Código de Comercio (Título II, reformado; texto vigente con última reforma DOF 14-11-2025) la define y le da los mismos efectos que la firma autógrafa y admisibilidad como prueba (art. 89), prohíbe negarle efectos por ser mensaje de datos (89 bis), establece presunciones de atribución (90, 90 bis), equivalencia funcional de forma escrita y firma (93) y el estándar de fiabilidad (97). En materia civil, el CCF admite consentimiento expreso por medios electrónicos (1803) y tiene por cumplida la forma escrita si la información es íntegra, atribuible y accesible (1834 bis). Procesalmente, el CFPC art. 210-A sigue aplicándose pero el código fue abrogado por decreto DOF 07-06-2023 con vacatio máxima al 01-04-2027; su sucesor, el CNPCF (última reforma DOF 15-01-2026), reproduce y amplía la regla (arts. 348-350), define legalmente la "firma electrónica simple" (art. 2 fr. XXI) y consagra equivalencia funcional probatoria (art. 308). En Querétaro el CNPCF aún no entraba en vigor a julio de 2026 (declaratoria local en trámite/aplazada, reportada para sept-2026). La Ley de Firma Electrónica Avanzada NO rige actos entre particulares (solo actos ante la APF). La SCJN (1a./J. 16/2019, registro 2019919) confirma que mecanismos simples (NIP) son firma electrónica, pero impone al operador del sistema la carga inicial de probar la fiabilidad del método: SATAV debe poder demostrar técnicamente atribución e integridad (hash, sello de tiempo, bitácora, versión del reglamento). El acto escuela-usuario es de naturaleza civil (no mercantil), lo que no debilita la validez: los estándares civil y mercantil convergen en la regla de "fiabilidad del método". Para menores de preparatoria, el contrato debe firmarlo padre/madre/tutor (CCF 635 y 637: nulidad relativa de actos de incapaces).

Implicación práctica para SATAV

La firma electrónica simple de SATAV es legalmente suficiente para la aceptación del reglamento: ni la LFEA ni la e.firma del SAT son exigibles a un acto entre particulares (LFEA arts. 3-4); el estándar aplicable es fiabilidad del método + atribución + integridad + accesibilidad (CCF 1834 bis, CFPC 210-A, CNPCF 349).

Conforme a 1a./J. 16/2019, si un padre/maestro niega haber firmado, el IAQ (operador del sistema) tendrá la carga probatoria INICIAL de demostrar la fiabilidad de su flujo: SATAV debe poder reconstruir end-to-end cada aceptación (quién se autenticó, cuándo, qué texto exacto vio, qué firmó, hash resultante) — la imagen PNG de la firma por sí sola no basta.

La firma debe capturarse SIEMPRE dentro de una sesión autenticada de Supabase Auth: el art. 90 fr. II CCom presume que el mensaje proviene del emisor cuando se usan 'claves o contraseñas del Emisor'; una firma capturada en página pública sin login pierde esa presunción de atribución.

El hash SHA-256 debe calcularse sobre el TEXTO ÍNTEGRO de la versión exacta del reglamento (las 22 cláusulas) concatenado con los datos del firmante y almacenarse junto con la versión, no solo sobre la imagen: así se satisface la detectabilidad de alteraciones del art. 97 frs. III-IV CCom y la 'forma original' del 210-A CFPC / 350 CNPCF.
Para alumnos de preparatoria menores de 18 años, la aceptación debe firmarla el padre/madre/tutor (CCF 635 y 637: el contrato del menor es anulable a instancia del propio menor y el IAQ no puede oponerlo); el formulario debe capturar fecha de nacimiento o bandera de minoría y enrutar la firma al tutor como 'gestionante'.
Una controversia sobre el reglamento se litigaría hoy (julio 2026) como juicio CIVIL en tribunales de Querétaro bajo el código procesal local (el CNPCF aún no entra en vigor en el estado, reportado para sept-2026, tope nacional 01-04-2027); el diseño probatorio debe funcionar bajo ambos regímenes — lo hace, porque ambos valoran la fiabilidad del método.
El registro del cobro de \$100 MXN en efectivo no convierte el acto en mercantil (no hay especulación comercial, art. 75 CCom); mantenerlo como 'registro contable' interno es correcto y evita atraer obligaciones de proveedor mercantil.
Conservación: el expediente de firma (PNG, trazos vectoriales JSON, hash, timestamp, versión del reglamento, user_id, metadatos de sesión) debe ser inmutable y accesible 'para su ulterior consulta' durante toda la vigencia del TAG y el plazo de prescripción de acciones (recomendable ≥10 años por analogía con el art. 49 CCom); nunca sobrescribir al re-firmar una nueva versión del reglamento — crear un registro nuevo.

A.4. NOM-151 y conservación

La NOM-151-SCFI-2016 (DOF 30-mar-2017, en vigor desde el 26-sep-2017, cancela la NOM-151-SCFI-2002) sigue VIGENTE en julio de 2026 sin modificación definitiva publicada. Regula dos cosas: (A) la conservación de mensajes de datos mediante "constancias de conservación" —sellos digitales de tiempo RFC 3161 en formato ASN.1 emitidos por Prestadores de Servicios de Certificación (PSC) acreditados por la Secretaría de Economía sobre la huella SHA-256 del documento (el PSC nunca recibe el documento, solo el hash)— y (B) la digitalización de documentos en soporte físico controlada por un Tercero Legalmente Autorizado. Su fundamento es el art. 49 CCom (obligación de comerciantes de conservar 10 años, con integridad e inalterabilidad conforme a la NOM). Es obligatoria SOLO para comerciantes en actos de comercio; el IAQ es una asociación civil y la aceptación de un reglamento de estacionamiento escolar es un acto civil, por lo que para SATAV la NOM-151 es OPCIONAL pero recomendable como estándar probatorio: la constancia da fecha cierta e integridad verificables por un tercero acreditado (verificación del Apéndice A.5: "el mensaje de datos existe, al menos, desde la fecha asentada... y es íntegro"), mientras que un hash + sello de tiempo propio se valora solo bajo el criterio general de "fiabilidad del método" (arts. 348-350 CNPCF, 1298-A CCom) y es evidencia autogenerada por la parte interesada. Costo de mercado: ~\$14-90 MXN por constancia vía API (AllSign \$14-45, Mifiel ~\$89). Para fase 1 de SATAV basta hash SHA-256 + timestamp propio en tabla append-only; la constancia NOM-151 es una mejora de fase 2 barata (~350 firmas/año ≈ \$5,000-30,000 MXN/año) que además no expone datos personales porque solo se envía el hash al PSC.

Implicación práctica para SATAV
NO existe obligación legal de que SATAV cumpla la NOM-151: el IAQ es asociación civil y la aceptación del reglamento de estacionamiento es acto civil, no de comercio (arts. 3o y 49 CCom; numeral 2 de la NOM). Adoptarla total o parcialmente es una decisión de robustez probatoria, no de cumplimiento.
Fase 1 (actual) es defendible sin PSC: la combinación imagen de firma + trazos vectoriales + SHA-256 del texto exacto + versión del reglamento + timestamp satisface el estándar de 'fiabilidad del método' de los arts. 348-350 CNPCF, SIEMPRE que el registro sea inmutable (append-only) y se conserve la atribución (usuario autenticado de Supabase Auth, correo verificado, IP/user-agent). El punto débil objetable es que el sello de tiempo lo genera la propia BD del IAQ.
Mejora de fase 2 recomendada y barata: pedir una constancia NOM-151 por CADA firma vía API (solo se manda el hash SHA-256, cero datos personales al PSC). Con ~300-500 firmas/año el costo anual estimado es \$5,000-\$30,000 MXN (\$14-\$90 MXN por constancia). Alternativa aún más barata: una constancia DIARIA o SEMANAL sobre el hash raíz de un árbol Merkle de las firmas del periodo (1 constancia ampara N firmas), reduciendo el costo a ~\$500-\$2,000 MXN/año; es criptográficamente equivalente para probar existencia-a-fecha.
El hash que SATAV sella debe cubrir el PAQUETE completo de evidencia, no solo el texto del reglamento: hash(texto exacto de la versión del reglamento + PNG de la firma + JSON de trazos + identificador del firmante + timestamp declarado). Hoy el hash es solo del texto firmado; si el PNG de la firma se altera en el bucket, el hash actual no lo detectaría.

Contratar solo con Prestadores de Servicios de Certificación incluidos en el directorio oficial de la Secretaría de Economía, o plataformas que declaren expresamente qué PSC acreditado emite la constancia. Si se usa un intermediario comercial, verificar en el contrato cuál es el PSC emisor.

Aunque el plazo de 10 años del art. 49 CCom no obliga al IAQ, conviene adoptarlo como política de retención de la evidencia de firma (coincide con la vigencia mínima de la constancia, Apéndice A.8.4.1) y documentarlo en el aviso de privacidad como plazo de conservación con fin de defensa legal; al vencer, suprimir conforme a la LFPDPPP 2025.

Si el IAQ quisiera dar valor de 'original' a reglamentos firmados en PAPEL de ciclos anteriores digitalizándolos, eso SÍ exige un PSC acreditado como Tercero Legalmente Autorizado (numeral 5.3.2 y Apéndice B; solo Cecoban, Seguridata, ATEB y Notaría 230 lo están) — no basta escanearlos. Para el flujo nativo digital de SATAV esto no aplica.

La firma de SATAV es electrónica SIMPLE: no goza de la equivalencia automática con la autógrafa que el art. 936 fr. III CNPCF reserva a la firma AVANZADA. La constancia NOM-151 no convierte la firma en avanzada ni prueba QUIÉN firmó; prueba QUÉ existía y DESDE CUÁNDO. La atribución debe seguir descansando en Supabase Auth + metadatos. Si algún día se requiere no-repudio fuerte (p. ej. adeudos), el salto es a firma avanzada (e.firma SAT) o proveedor con verificación de identidad, no a más sellos.

A.5. Menores de edad

A julio de 2026 rige la nueva LFPDPPP (DOF 20-03-2025, última reforma 14-11-2025), que abrogó la ley de 2010 y trasladó la autoridad garante del extinto INAI a la Secretaría Anticorrupción y Buen Gobierno. Verificado contra el texto oficial: la nueva ley NO contiene ningún artículo expreso sobre menores (no aparecen "niñas, niños y adolescentes" ni "interés superior" en su articulado); la protección de menores se construye con el art. 4o CPEUM (interés superior de la niñez), la LGDNNA arts. 76-80 (intimidad y datos de NNA; alumnos de prepa <18 son "adolescentes" per art. 5) y el CCF (arts. 23, 424, 425, 646): el menor de 18 no puede obligarse por sí; consienten y firman quienes ejercen la patria potestad/tutela, que son sus legítimos representantes. El Reglamento LFPDPPP 2011 sigue listado como vigente y su art. 89 remite el ARCO de menores a las reglas de representación del CCF. Para SATAV: cuando tipo_usuario=alumno menor de edad, el gestionante (padre/tutor) debe ser quien firme la aceptación del reglamento; el aviso de privacidad debe mencionar el tratamiento de datos de menores y la videovigilancia; los trazos de firma son potencialmente dato biométrico conductual y exigen resguardo reforzado.

Implicación práctica para SATAV

FIRMA DEL MENOR: cuando tipo_usuario='alumno' y el titular es menor de 18 años, la firma jurídicamente vinculante (aceptación del reglamento + consentimiento de datos + obligación del pago de \$100) debe ser del padre/madre/tutor — es decir, el 'gestionante' del modelo SATAV debe ser obligatoriamente quien firma (CCF arts. 23, 424, 425 y 646; Reg. LFPDPPP art. 89 último párrafo). La firma del alumno menor puede recabarse ADEMÁS como constancia de su opinión/enteramiento (estándar dual de LGDNNA art. 78: consentimiento del tutor + opinión del adolescente), pero nunca como única firma.

DETECCIÓN DE MINORÍA: el flujo de autoservicio debe capturar fecha de nacimiento (o al menos una declaración explícita de mayoría/minoría de edad) cuando tipo_usuario='alumno'; si es menor, la UI debe bifurcar: bloquear el flujo en solitario y exigir nombre, contacto, parentesco (patria potestad/tutela, declarado bajo protesta de decir verdad) y firma del gestionante. Los alumnos de prepa ya mayores de 18 sí pueden firmar por sí mismos (CCF arts. 24 y 646).

AVISO DE PRIVACIDAD: debe existir aviso integral del IAQ AC con las 6 fracciones del art. 15 LFPDPPP 2025 (identidad y domicilio del responsable, datos tratados identificando sensibles si los hubiera, finalidades, opciones para limitar uso, mecanismos ARCO, procedimiento de cambios) y mencionar EXPRESAMENTE: (i) que se tratan datos de menores de edad con consentimiento de quien ejerce la patria potestad/tutela, (ii) la videovigilancia 24h del estacionamiento, (iii) la firma digitalizada y sus trazos como evidencia. En el formulario web basta el aviso simplificado (fracciones I-IV) con enlace al integral (art. 16 fr. II). No se necesita cláusula de transferencia por usar Supabase/AWS (son encargados, art. 2 frs. XII y XX), pero conviene nombrarlos como encargados en el aviso integral por transparencia.

CONSENTIMIENTO SIEMPRE EXPRESO EN ESTE FLUJO: aunque la regla general de la ley 2025 es el consentimiento tácito, SATAV no debe apoyarse en él: el registro del cobro de \$100 asociado a la persona es dato patrimonial (consentimiento expreso obligatorio, art. 7 párr. 5) y, tratándose de menores, el interés superior (CPEUM art. 4o, LGDNNA) exige consentimiento expreso y verificable del representante. La firma electrónica simple reforzada (imagen + trazos + SHA-256 + sello de tiempo + versión del reglamento) satisface el estándar de 'medios electrónicos' del art. 7 e incluso el del art. 8 para sensibles.

ARCO DE MENORES: las solicitudes de acceso/rectificación/cancelación/oposición sobre registros de alumnos menores solo pueden atenderse al padre/tutor acreditado (identidad del titular + identidad del representante + representación, Reg. art. 89); nunca entregar datos de un menor a un tercero que no acredite la patria potestad. Hay que designar formalmente a la persona/departamento de datos personales del IAQ (art. 29) y respetar los plazos 20+15 días (art. 31). Las solicitudes de cambio/baja del TAG que ya contempla SATAV deben canalizar también esto.

VIDEOVIGILANCIA: la cláusula de videovigilancia 24h del reglamento no basta por sí sola: se requiere señalética física en los accesos y zonas del estacionamiento (aviso corto: responsable, finalidad, derechos, dónde ver el aviso integral) y un plazo de conservación de grabaciones definido y corto. Ventaja probatoria de SATAV: como el texto íntegro del reglamento (incluida la cláusula de videovigilancia) queda hashado con SHA-256 y firmado, el IAQ puede probar que cada usuario —o el tutor del menor— conoció y aceptó la videovigilancia.

FIRMA COMO BIOMÉTRICO CONDUCTUAL: los trazos vectoriales (con timing/velocidad) encajan en la noción de biométrico de comportamiento de la guía INAI; no son dato sensible per se, pero exigen seguridad reforzada y minimización: usarlos únicamente como evidencia de la firma, no para identificación automatizada, y no exponerlos jamás por endpoints públicos.

RETENCIÓN Y SUPRESIÓN: definir plazo de conservación (p.ej. vigencia del TAG + plazo de prescripción de responsabilidades; la ley usa 72 meses como referencia para incumplimientos contractuales, art. 10 párr. 3) y suprimir previo bloqueo los registros y las imágenes de firma al agotarse la finalidad (art. 10). Los datos de menores no deben conservarse indefinidamente 'por si acaso'.

A.6. Seguridad y vulneraciones

A julio de 2026 el deber de seguridad de particulares en México se rige por la NUEVA LFPDPPP (DOF 20-03-2025, vigor 21-03-2025, última reforma DOF 14-11-2025), que abrogó la ley de 2010: el deber de seguridad está en el art. 18 (antes 19), la notificación de vulneraciones en el art. 19 (antes 20) y la confidencialidad en el art. 20 (antes 21). La notificación de vulneraciones se debe SOLO al titular, "de forma inmediata" cuando afecten de forma significativa sus derechos patrimoniales o morales; NO existe obligación de notificar a la autoridad ni plazo de 72 horas (a diferencia del GDPR). La autoridad es ahora la Secretaría Anticorrupción y Buen Gobierno (art. 3 fr. XV), que sustituyó al INAI. No se ha publicado un nuevo Reglamento: el Reglamento de 2011 (DOF 21-12-2011) sigue siendo el único existente y aplicable en lo que no se oponga a la ley nueva; su Capítulo III (arts. 57-66) detalla las acciones de seguridad (inventario, análisis de riesgos y de brecha, plan de trabajo, auditorías, capacitación, registro de medios) y desarrolla la notificación: "sin dilación alguna" tras confirmar la vulneración (art. 64) con contenido mínimo de 5 puntos (art. 65). Para particulares es obligatoria una "relación de medidas de seguridad" (art. 61 in fine RLFPDPPP), no un "documento de seguridad" formal (ese es del sector público), aunque el INAI lo recomendó como buena práctica. Vulnerar la seguridad de bases de datos imputable al responsable se multa con 200 a 320,000 UMA (arts. 58 fr. XI y 59 fr. III): hasta ~\$37.5M MXN con UMA 2026 (\$117.31), duplicable con datos sensibles, más posible delito (art. 62). Todo el mapeo es implementable en el stack SATAV con RLS de Supabase, cifrado AES-256 en reposo y TLS en tránsito (verificado en docs oficiales), bucket privado para firmas, bitácora y respaldos diarios.

Implicación práctica para SATAV

IAQ (asociación civil privada) es 'responsable' y 'sujeto regulado' (art. 3 frs. XIV y XVI LFPDPPP 2025) por nombres, placas, firmas y datos de contacto de padres, maestros y alumnos de preparatoria; Supabase/AWS son 'persona encargada' (art. 3 fr. XII) vía nube por adhesión, por lo que el checklist del art. 52 RLFPDPPP debe verificarse y documentarse: SOC 2 Type 2 + ISO 27001 + lista pública de subprocesadores de Supabase cubren las fracciones I.a-d y II.a-e (descargar evidencia de trust.supabase.com y archivarla en la relación de medidas de seguridad).

El art. 18 exige calibrar medidas por 'las posibles consecuencias para las personas titulares' y el art. 60 RLFPDPPP añade 'el riesgo por el valor potencial... para una tercera persona no autorizada': en SATAV hay dos activos de riesgo alto que obligan a medidas reforzadas aunque no sean 'datos sensibles' legales: (1) la imagen de la firma manuscrita (utilizable para suplantación/falsificación documental) y (2) el binomio placas+tipo de usuario 'alumno', que permite identificar y ubicar vehículos de MENORES en horarios predecibles; ambos justifican bucket privado, acceso solo-admin y no exponer placas en listados abiertos.

Si un tercero accede sin autorización a la tabla de registros o al bucket de firmas (vulneración art. 63 frs. II/III RLFPDPPP), IAQ debe: confirmar el incidente, detonar revisión exhaustiva de magnitud, y notificar 'sin dilación alguna' (art. 64) SOLO a los titulares afectados (padres/maestros/alumnos; si el alumno es menor, a quien ejerza la patria potestad) con los 5 contenidos del art. 65; NO hay obligación de notificar a la Secretaría Anticorrupción, pero atender sus recomendaciones atenúa sanciones (art. 58 RLFPDPPP). SATAV debe poder generar la lista de afectados por consulta (qué filas/archivos tocó el atacante) — eso exige bitácora consultable.

Riesgo económico concreto de una brecha imputable: infracción art. 58 fr. XI LFPDPPP con multa de 200 a 320,000 UMA (hasta ~\$37.5M MXN a valores UMA 2026); la 'capacidad económica del responsable' (art. 60 fr. IV) modula el monto para una escuela AC, pero la cifra justifica que el costo de configurar RLS/bucket privado/respaldos es trivial frente a la exposición. Si personal interno con acceso (Admin/TI) provocara la vulneración con ánimo de lucro, hay además delito con prisión de 3 meses a 3 años (art. 62).
Obligación documental mínima VIGENTE: no se requiere 'documento de seguridad' formal (figura del sector público), pero sí la 'relación de las medidas de seguridad' del art. 61 in fine RLFPDPPP, producto de las 9 acciones del propio art. 61. Para SATAV: inventario de datos (tablas Postgres + bucket de firmas + registro contable del cobro de \$100), matriz de funciones por rol (maestro/padre/alumno/admin/TI), análisis de riesgos y de brecha, plan de trabajo, y actualizarla tras cada incidente (art. 62 fr. III). Elaborar además un documento de seguridad estilo INAI es buena práctica recomendable y barata dado que el sistema es pequeño.
El deber de confidencialidad del art. 20 LFPDPPP alcanza al personal de Administración y TI del IAQ que opera el panel admin y ve placas/firmas/observaciones: firmar compromisos de confidencialidad que expresamente subsistan al terminar la relación laboral, y revocar cuentas de Supabase/panel el mismo día de la baja del empleado (des-provisionamiento como medida administrativa del art. 18).
El campo de 'observaciones libres' es el punto ciego típico: puede acabar conteniendo datos de salud u otros sensibles capturados por admins ('alumno con discapacidad usa cajón especial'), lo que duplicaría multas (art. 59 fr. IV). Mitigar con instrucción de captura, validación/limitación del campo y revisión periódica; idealmente catálogo cerrado de motivos.
La videovigilancia 24h mencionada en el reglamento del estacionamiento genera datos personales (imágenes) del mismo responsable IAQ: aunque SATAV no almacene video, el análisis de riesgos y la relación de medidas deben declarar ese tratamiento conexo, y el aviso de privacidad que se firma en SATAV es el vehículo natural para informarlo; una vulneración del sistema de video también dispararía arts. 19 LFPDPPP y 64-65 RLFPDPPP.

A.7. Nube, encargados y transferencias

A julio de 2026 rige la nueva LFPDPPP (DOF 20/03/2025, vigente desde 21/03/2025, última reforma DOF 14/11/2025), que abrogó la ley de 2010 y trasladó la autoridad a la Secretaría Anticorrupción y Buen Gobierno. La ley nueva define "persona encargada" y "transferencia" (que EXCLUYE la comunicación al encargado), pero casi no regula al encargado ni la nube: ese régimen sigue en el Reglamento de 2011 (arts. 49-56: obligaciones del encargado, formalización contractual, condiciones para cómputo en la nube, remisiones sin consentimiento, subcontratación), que continúa aplicable porque no se ha expedido reglamento nuevo y la propia ley lo presupone. Enviar los datos de SATAV a Supabase/AWS en EE.UU. es una REMISIÓN internacional a encargado —no una transferencia—, por lo que no exige consentimiento ni cláusula de aceptación, pero sí exige cumplir el art. 52 del Reglamento (verificación del proveedor de nube) y formalizar la relación (los Términos de Servicio + el DPA oficial de Supabase, firmable desde el dashboard, satisfacen el art. 51). Supabase: processor bajo DPA (14/03/2025), subprocessadores en Schedule 3 (AWS hosting de cada BD, Google/BigQuery logs, Cloudflare, Fly.io, Vercel), sin región en México (más cercanas us-east-1/us-west-1/2), AES-256 en reposo, TLS 1.2+ en tránsito, llaves por proyecto en HSM FIPS 140-2, SOC 2 Type 2 + ISO 27001 + HIPAA. Cloudflare/GoDaddy en el diseño de SATAV no tratan datos personales del sistema (front estático; el navegador habla directo con *.supabase.co), aunque Cloudflare sí es subprocessador de Supabase. El aviso de privacidad debe informar el uso de encargados de nube en EE.UU. y contener cláusula de transferencias (aunque sea para negarlas), pues omitir elementos del art. 15 es infracción sancionable (arts. 58-59: multas de hasta 320,000 UMA).

Implicación práctica para SATAV
Roles: el IAQ (asociación civil) es el RESPONSABLE (art. 2 frs. XIV/XVI LFPDPPP 2025); Supabase, Inc. es PERSONA ENCARGADA (fr. XII); AWS, Google, Cloudflare, Fly.io y Vercel son subprocessadores del encargado autorizados vía Schedule 3 del DPA (arts. 54-55 Reglamento). Subir placas, firmas PNG y datos de contacto al proyecto Supabase en EE.UU. es una REMISIÓN internacional, no una transferencia: NO requiere consentimiento del padre/maestro/alumno ni cláusula de aceptación (art. 2 fr. XX Ley + art. 53 Reglamento).
Acción concreta obligatoria: firmar el DPA de Supabase (solicitarlo en Dashboard → Organization → Legal Documents, vía PandaDoc, disponible en cualquier plan de pago) y archivar el PDF firmado + los Terms of Service versionados. Con eso se cumple la formalización del art. 51 del Reglamento sin necesidad de contrato negociado; solo los ToS sin DPA dejarían débiles las condiciones del art. 52 (supresión garantizada, notificación de brechas, subcontrataciones).

Verificación art. 52 del Reglamento ya satisfecha documentalmente por Supabase: políticas de privacidad publicadas (fr. I a), Schedule 3 transparente subcontrataciones (fr. I b), los ToS no reclaman propiedad de los datos del cliente (fr. I c), DPA cl. 6 confidencialidad (fr. I d), aviso de 30 días por cambios de subprocesadores (fr. II a), controles de acceso/RLS (fr. II b y e), SOC 2 Type 2 + ISO 27001 + AES-256/TLS (fr. II c), cl. 12.2 supresión con ventana de recuperación de 30 días (fr. II d). Guardar este mapeo en el expediente de cumplimiento de SATAV como evidencia del principio de responsabilidad (art. 5).

Aviso de privacidad de SATAV (arts. 14-16 Ley): debe publicarse el aviso integral en el sitio y un aviso simplificado en el formulario de registro (art. 16 fr. II: al recabar por medios electrónicos se da el simplificado con frs. I-IV del art. 15 + link al integral). Cláusulas específicas de nube: (1) identidad y domicilio del IAQ como responsable; (2) lista de datos tratados (nombre, placas, marca/modelo/color, tipo de usuario, firma manuscrita digital, contacto) señalando que ninguno es sensible; (3) finalidades; (4) sección 'Encargados y cómputo en la nube': informar que los datos se alojan con Supabase, Inc. sobre infraestructura AWS en EE.UU., cifrados, como encargados del tratamiento — no es legalmente exigible pedir consentimiento por esto, pero informarlo cumple el principio de información y la recomendación INAI; (5) cláusula de transferencias: declarar que el IAQ NO transfiere datos a terceros salvo los supuestos del art. 36 (p.ej. requerimiento de autoridad competente) — la omisión de esta cláusula es infracción del art. 58 fr. V.

Si en el futuro los datos del TAG se comparten con un tercero distinto (empresa operadora del estacionamiento, aseguradora, otra escuela), eso SÍ sería transferencia: exigiría comunicar el aviso al receptor, cláusula de aceptación en el aviso (art. 35) y, si es internacional, instrumento jurídico tipo art. 75 del Reglamento. Diseñar el aviso desde ahora con esa cláusula condicionada evita re-consentir después (art. 11: nueva finalidad = nuevo consentimiento).

Región del proyecto: elegir us-east-1 o us-west-1/2 y DOCUMENTAR la elección con el análisis de jurisdicción recomendado por los criterios INAI (EE.UU. sin ley federal general de datos, mitigado por DPA+SCCs 'Global Transfers'+cifrado AES-256/TLS+TIA de Supabase). No existe región Supabase en México; si el IAQ exigiera residencia nacional habría que auto-hospedar Supabase en AWS mx-central-1, fuera del alcance actual del proyecto.

Ciclo de vida: implementar la supresión efectiva cuando se dé de baja un TAG o concluya la relación con el titular (art. 10 Ley: supresión previa bloqueo; art. 50 fr. V Reglamento como instrucción al encargado). En la práctica: borrar el PNG de la firma del bucket privado y los registros de la tabla, o disociarlos; y si el IAQ migra de proveedor, ejecutar el export de la cl. 12.2 del DPA dentro de los 30 días.

Cloudflare/GoDaddy: en el diseño actual (front estático + llamadas directas del navegador a *.supabase.co) no son encargados del IAQ y no necesitan contrato de datos; GoDaddy solo registra el dominio. Evitar cachear/proxyear la API de Supabase con un dominio propio detrás de Cloudflare; si se hiciera (custom domain), aceptar el Cloudflare Customer DPA porque Cloudflare pasaría a procesar en tránsito las placas y firmas como encargado directo.

A.8. ARCO y videovigilancia

A julio de 2026 rige la NUEVA Ley Federal de Protección de Datos Personales en Posesión de los Particulares (DOF 20/03/2025, vigente desde 21/03/2025), que abrogó la ley de 2010; su única reforma (DOF 14/11/2025) solo cambió el art. 4 (supletoriedad del Código Nacional de Procedimientos Civiles y Familiares), por lo que el régimen ARCO del texto original sigue intacto. Los derechos ARCO están en los arts. 21-34: plazos de 20 días para responder + 15 días para ejecutar (ampliables una sola vez por periodo igual, art. 31), ejercicio gratuito (art. 34), revocación del consentimiento en cualquier momento con mecanismos que DEBEN constar en el aviso de privacidad (art. 7), y obligación de designar una persona o departamento de datos personales (art. 29, equivalente del antiguo art. 30 de la ley 2010). La autoridad garante es ahora la Secretaría Anticorrupción y Buen Gobierno (INAI extinto). En videovigilancia, el criterio oficial del INAI (comunicado INAI/041/2025 y modelo de aviso corto para V-V de 2016) es que las imágenes que identifican o hacen identificables a personas son datos personales; se requiere cartel/aviso de privacidad corto en los accesos a la zona videovigilada MÁS un aviso de privacidad integral — el reglamento de 22 cláusulas del estacionamiento no basta por sí solo. Las placas de circulación se consideran dato personal (confidencial) en criterios oficiales derivados de resoluciones del INAI, al hacer identificable al propietario. Incumplir ARCO es infracción sancionable con multas de 100 hasta 320,000 UMA (art. 58 fr. I-II y 59).

Implicación práctica para SATAV

El IAQ (asociación civil privada) es 'responsable' bajo la LFPDPPP 2025 federal; la ley de datos de Querétaro solo aplica a sujetos obligados públicos. Todo el compliance de SATAV debe citar la ley 2025, NO la de 2010 (abrogada): p.ej. la obligación de designar encargado de datos es hoy el art. 29 (no el 30) y los plazos ARCO son el art. 31 (no el 32).

El IAQ debe designar formalmente (por escrito/acta interna) a una persona o departamento de datos personales (art. 29). Puede ser el depto. de TI o Administración del IAQ, pero conviene nombrar a un titular concreto con correo dedicado (p.ej. datospersonales@iaq.edu.mx) que aparezca en el aviso de privacidad de SATAV, porque las solicitudes ARCO de padres/maestros/alumnos llegarán por ahí.

El aviso de privacidad de SATAV debe incluir obligatoriamente (art. 15): identidad y domicilio del IAQ, listado de datos tratados (nombre, placas, marca/modelo/color, tipo de usuario, firma manuscrita digital, datos de contacto, registro del cobro de \$100 MXN) identificando si alguno es sensible (ninguno de los listados lo es per se), finalidades, medios para limitar uso, mecanismos ARCO y procedimiento de cambios al aviso. Como los datos se recaban por medio electrónico, el formulario de autoservicio debe mostrar el aviso SIMPLIFICADO (fracciones I-IV del art. 15) antes de la firma, con enlace al aviso integral (art. 16 fr. II) — mismo patrón de versión exacta + hash que ya se usa con el reglamento.

Los alumnos de preparatoria menores de edad no tienen régimen especial expreso en la ley 2025, pero el consentimiento debe otorgarlo quien ejerza la patria potestad/tutela (representante legal, arts. 21 y 27-28): el flujo de SATAV debe capturar si el gestionante es padre/madre/tutor cuando el titular es menor, y la firma de aceptación debe ser del representante, no del menor.

Plazos duros que el panel debe soportar: 20 días para comunicar la determinación ARCO y 15 días para ejecutarla, con UNA prórroga posible por periodo igual (art. 31). Recomendado SLA interno de 10-15 días. La respuesta debe darse por el mismo medio de la solicitud (art. 33 último párrafo) y en acceso debe verificarse identidad antes de entregar (art. 31, segundo párrafo). El ejercicio es gratuito (art. 34): no puede condicionarse a pago, salvo costos de copias/envío.

El panel admin DEBE poder: (a) exportar todos los datos de un titular (acceso, art. 22/32 — basta documento electrónico); (b) corregir cualquier campo con evidencia documental (rectificación, arts. 23 y 30); (c) cancelar con BLOQUEO previo a supresión (art. 24): un registro cancelado pasa a estado 'bloqueado' (no tratable, solo conservado para responsabilidades) durante el plazo de prescripción de la relación jurídica del TAG, y después se suprime definitivamente, avisando al titular; (d) registrar oposiciones y revocaciones. Ojo: mientras el TAG esté vigente, el IAQ puede negar la cancelación de los datos necesarios para el contrato (art. 25 fr. I), documentando el motivo.

La revocación del consentimiento (art. 7) exige un mecanismo explícito descrito en el aviso de privacidad: el módulo de solicitudes de cambio/baja de SATAV puede fungir como ese mecanismo si se documenta; la revocación no es retroactiva (lo ya tratado lícitamente no se 'borra' por revocar, pero cesa el tratamiento futuro y detona el flujo de cancelación/bloqueo).

Videovigilancia: la cláusula de '24 horas' en el reglamento de 22 cláusulas NO basta. Se requiere: (1) CARTEL con aviso de privacidad corto en cada acceso al estacionamiento (identidad y domicilio del IAQ, finalidad de seguridad, dónde consultar el aviso integral, leyenda de zona videograbada — modelo INAI 2016); (2) aviso de privacidad INTEGRAL que cubra videovigilancia (puede ser una sección del aviso de SATAV o uno específico publicado en el sitio); (3) política de retención de grabaciones definida y justificada (no hay plazo legal fijo; 30-90 días es práctica defendible bajo arts. 10 y 12); (4) prohibición interna de difundir grabaciones (WhatsApp/redes) — es infracción multable; solo entrega al Ministerio Público como prueba; (5) posibilidad real de ejercer ARCO sobre las imágenes ante el encargado de datos del IAQ.